

CertGraph: Heterogeneous Graph Attention Networks for Active Directory Certificate Services Vulnerability Detection and Autonomous Defense

Course Code: ECE 402

Course Title: Project and Thesis

Submitted By—

Student ID: 2002126 Level: 4, Semester: I

Student ID: 2002138 Level: 4, Semester: I

Student ID: 2102151 Level: 4, Semester: I



Submitted To—

Department of Electronics and Communication Engineering

in partial fulfillment of the requirements for the degree of

Bachelor of Science in Electronics and Communication Engineering

Hajee Mohammad Danesh Science and Technology University (HSTU)

Dinajpur-5200, Bangladesh

February, 2025

Certificate

This is to certify that the thesis work entitled “**CertGraph: Heterogeneous Graph Attention Networks for Active Directory Certificate Services Vulnerability Detection and Autonomous Defense**” is carried by the following ID numbers: **2002126, 2002138, 2102151**. To the fullest extent of our knowledge, we assert that this undertaking is an authentic and original contribution to the field. We certify that this thesis has not been previously submitted for the award of any other degree or diploma at this or any other institution.

Signed by the Final Examining committee:

.....
Chairman
Examination Committee

.....
Supervisor
Department of ECE, HSTU

.....
External Member
Examination Committee

.....
Co-Supervisor
Department of ECE, HSTU

.....
Internal Member
Examination Committee

Candidate's Declaration

We hereby declare that the research work presented in this thesis entitled “**CertGraph: Heterogeneous Graph Attention Networks for Active Directory Certificate Services Vulnerability Detection and Autonomous Defense**” is the outcome of an original investigation conducted by us under the supervision of the Department of Electronics and Communication Engineering, Hajee Mohammad Danesh Science and Technology University (HSTU), Dinajpur-5200, Bangladesh.

We further solemnly declare that:

1. This work, or any part thereof, has not been submitted previously to any university or institution for the award of any degree, diploma, or other academic qualification.
2. All material, concepts, and algorithms taken from the published or unpublished work of others have been fully and properly acknowledged and cited in accordance with standard academic referencing protocols.
3. All synthetic datasets, forensic auditing scripts, empirical benchmark routines, and graph learning models described herein were constructed with rigorous adherence to ethical scientific standards and academic integrity.

Date: February, 2025

Place: HSTU, Dinajpur

.....

Student ID: 2002126

Student ID: 2002138

Student ID: 2102151

Department of ECE, HSTU

Dedication

*This thesis is dedicated to our beloved parents,
whose endless sacrifices, prayers, and unconditional love
have been the guiding light of our lives.*

*And to all our respected teachers and mentors,
who inspired our passion for engineering and scientific discovery.*

Acknowledgements

First and foremost, all praises are due to Almighty Allah, the Most Merciful and Most Beneficent, who bestowed upon us the health, strength, patience, and intellect required to complete this project and thesis research successfully.

We express our profound gratitude, respect, and deepest indebtedness to our respected thesis supervisor and co-supervisor in the Department of Electronics and Communication Engineering, Hajee Mohammad Danesh Science and Technology University (HSTU), Dinajpur. Their exemplary guidance, insightful suggestions, constant encouragement, and critical academic reviews were invaluable throughout the formulation, mathematical derivation, experimental validation, and manuscript preparation of this research.

We are deeply thankful to the Chairman and all distinguished faculty members of the Department of Electronics and Communication Engineering, HSTU, for providing a vibrant academic environment, high-quality computational facilities, and continuous moral support during our undergraduate curriculum.

Our sincere gratitude goes to the global open-source cybersecurity and machine learning research communities. In particular, we acknowledge the pioneering work of Will Schroeder and Lee Christensen (SpecterOps) for uncovering the ADCS attack surface; the creators of BloodHound, SharpHound, and Certipy for their foundational offensive graph tools; the developers of the Game of Active Directory (GOAD) laboratory; and the core contributors of PyTorch Geometric and NetworkX.

Finally, we owe an immeasurable debt of gratitude to our parents and families for their unending sacrifices, patience, and blessings throughout our university education. We also express warm appreciation to our batchmates, lab peers, and friends whose intellectual discussions, camaraderie, and encouragement enriched every stage of this thesis journey.

HSTU, Dinajpur
February, 2025

Student ID: 2002126
Student ID: 2002138
Student ID: 2102151
Department of ECE, HSTU

Abstract

Active Directory Certificate Services (ADCS) is deployed across more than 90% of enterprise networks to administer Public Key Infrastructure (PKI) credentials for authentication and encryption. However, subtle architectural misconfigurations across certificate templates, Access Control Lists (ACLs), and issuance policies introduce catastrophic privilege escalation vectors (designated ESC1 through ESC15), enabling unprivileged actors to compromise entire Active Directory domains. Existing auditing utilities (Certipy, BloodHound, PSPKIAudit) are predominantly rule-based and signature-driven: they evaluate isolated template configuration flags via static heuristics without learning from global environment topology, reachability, or multi-hop delegation chains.

This thesis introduces **CertGraph**, the first heterogeneous Graph Neural Network architecture designed for structural vulnerability detection across Active Directory Certificate Services attack graphs. We formalize enterprise identity infrastructure as a typed, directed, heterogeneous multigraph $G = (V, E, \mathcal{T}_V, \mathcal{T}_E)$ and deploy a Heterogeneous Graph Attention Network (Hetero-GAT) equipped with relation-specific message passing and multi-head attention mechanisms to perform inductive node-level classification over certificate templates.

Crucially, our investigation was grounded in an end-to-end **Forensic Audit** of experimental methodology. We uncovered and eliminated critical structural illusions: synthetic positional index leakage (where administrative entities occupy predictable array offsets), baseline information asymmetry (where flat ML baselines are deprived of graph topological features), and test-set memorization under synthetic hard negatives. We mathematically prove that in directed heterogeneous identity graphs containing source-only entities (Users and Computers with zero in-degree), residual skip-connections are indispensable; without them, message-passing aggregation triggers catastrophic representation collapse ($h_v^{(l+1)} = \mathbf{0}$), causing Macro-F1 to collapse from 0.9986 to 0.4768 ($p = 1.31 \times 10^{-6}$).

On a sanitized, leakage-free benchmark of 700 enterprise environments evaluated under 5-fold cross-validation, CertGraph achieves a Macro-F1 score of **0.9986 ± 0.0029** , substantially outperforming signature heuristics ($0.7791 \pm 0.0247, p < 10^{-4}$) and flat ML ($0.8600 \pm 0.0130, p < 10^{-4}$). To probe model reliability, we formulated a novel **Zero-Shot Adversarial Hard Negative** benchmark where models trained on benign environments are tested against non-exploitable templates bearing vulnerable flags. Under this shift, neural models—including GNNs—succumb to shortcut learning, collapsing to 1.59% accuracy by relying on template flags rather than verifying path reachability. Conversely, symbolic graph traversal (BloodHound BFS) retains 84.13% accuracy.

These findings provide the first empirical justification for a **Neuro-Symbolic Hybrid Architecture** in enterprise identity defense: leveraging fast relational GNNs for heuristic risk prioritization ($O(1)$ amortized screening) coupled with symbolic graph algorithms for deterministic exploitability proofs. Finally, we formulate the autonomous edge-severing defense problem as a Stackelberg security game and mathematically prove its NP-hardness via reduction to the Directed Multi-way Cut problem.

Keywords: Active Directory Certificate Services (ADCS), Graph Attention Networks, Heterogeneous Graphs, Identity and Access Management, Neuro-Symbolic Security, Shortcut Learning, Autonomous Cyber Defense.

Table of Contents

List of Acronyms	ix
1 Introduction	1
1.1 The Modern Identity Attack Surface	1
1.2 The Rise of Active Directory Certificate Services (ADCS)	1
1.3 Limitations of Prior Art	1
1.4 Research Questions and Thesis Objectives	2
2 Background and Threat Model	2
2.1 Active Directory Architecture and Identity Primitives	2
2.2 Active Directory Certificate Services (ADCS) Mechanics	2
2.3 Taxonomy of ADCS Vulnerability Classes	3
3 Formal Methodology and CertGraph Architecture	4
3.1 Graph Formalization	4
3.2 CertGraph Hetero-GAT Pipeline	4
4 Forensic Audit: Unmasking Experimental Illusions	4
4.1 The Four Experimental Illusions	4
4.2 Generator Sanitization	5
5 Empirical Evaluation and Benchmarks	5
5.1 In-Distribution 5-Fold Cross-Validation	5
5.2 Architectural Ablations: Confirmation of Theorem 1	6
5.3 Zero-Shot Adversarial Hard Negative Benchmark	7
6 Real-World Active Directory Case Studies: GOAD	7
7 Domain Generalization, Robustness, and Scalability	8
8 The Neuro-Symbolic Paradigm	8
9 Game-Theoretic Autonomous Defense	9
9.1 Stackelberg Security Game Formulation	9
9.2 Complexity Proof (Theorem 2)	9
10 Conclusion	9
10.1 Summary of Findings	9
Appendix: Formal Mathematical Proofs	11
Proof of Theorem 1: Representation Collapse of Source-Only Entities	11
Proof of Theorem 2: NP-Hardness of Minimal-Capacity Edge-Severing	11
Bibliography	12

List of Figures

Figure 1: Heterogeneous Active Directory Certificate Services (ADCS) Graph Schema, showing relationships between security principals, templates, and CAs.	3
Figure 2: Two-hop ESC13 privilege escalation attack path from an unprivileged user through enrollment permissions and issuance policy OID linkage to high-value domain administrative group tokens.	3
Figure 3: CertGraph Hetero-GAT architectural pipeline, detailing relational multi-head attention, residual skip connections, and the 7-class classification head.	4
Figure 4: Correlation and separability heatmap of template configuration flags and augmented topological features across ESC vulnerability classes.	5
Figure 5: CertGraph Confusion Matrix	6
Figure 6: GNN Family Comparison	6
Figure 7: Ablation study showing catastrophic performance collapse when residual skip connections are disabled.	7
Figure 8: Zero-shot adversarial evaluation demonstrating the collapse of neural models (shortcut learning) compared to symbolic BFS path traversal.	7
Figure 9: ADSynth Tiered Transfer	8
Figure 10: Perturbation Robustness	8
Figure 11: Scalability benchmarks showing linear latency scaling and flat bounded RSS memory footprint.	8
Figure 12: The Two-Tier Neuro-Symbolic Architecture pairing fast CertGraph GNN screening with deterministic BloodHound BFS path verification.	9

List of Tables

Table 1: 5-Fold Cross-Validation Performance across 7 Evaluated Models on 700 Enterprise Domains. 6

List of Acronyms

ACL	Access Control List
AD	Active Directory
ADCS	Active Directory Certificate Services
AWDP	Automated Windows Domain Penetration
BFS	Breadth-First Search
CA	Certificate Authority
CSR	Certificate Signing Request
CV	Cross-Validation
DACL	Discretionary Access Control List
DC	Domain Controller
DDQN	Dueling Double Deep Q-Network
ECE	Electronics and Communication Engineering
EKU	Extended Key Usage
ESC	Escalation Vector (ADCS Misconfiguration Primitive)
GAT	Graph Attention Network
GCN	Graph Convolutional Network
GNN	Graph Neural Network
GOAD	Game of Active Directory
Hetero-GAT	Heterogeneous Graph Attention Network
HSTU	Hajee Mohammad Danesh Science and Technology University
IAM	Identity and Access Management
KDC	Key Distribution Center
LDAP	Lightweight Directory Access Protocol
ML	Machine Learning
MLP	Multi-Layer Perceptron
NP	Nondeterministic Polynomial Time
ODE	Ordinary Differential Equation
OID	Object Identifier
PAC	Privilege Attribute Certificate
PKI	Public Key Infrastructure
RF	Random Forest
SAN	Subject Alternative Name
SID	Security Identifier
SOC	Security Operations Center
TGS	Ticket Granting Service
TGT	Ticket Granting Ticket
XAI	Explainable Artificial Intelligence

1 Introduction

1.1 The Modern Identity Attack Surface

Enterprise security architectures have undergone a fundamental paradigm shift over the past decade. The traditional perimeter defense model—predicated on securing network boundaries via firewalls, intrusion detection systems, and demilitarized zones (DMZs)—has proven wholly inadequate against modern Advanced Persistent Threats (APTs) and sophisticated ransomware operators. Today, the true operational perimeter of an enterprise is its **identity and access management (IAM) fabric**. Within this fabric, Microsoft Active Directory (AD) stands as the undisputed centerpiece, deployed across more than 90% of Fortune 1000 organizations and global enterprise IT infrastructures to manage authentication, authorization, and directory services.

Active Directory is not merely a database of usernames and passwords; it is an immensely dense, dynamic, and heterogeneous relational graph. Entities such as user accounts, computer workstations, domain controllers, security groups, and organizational units are interlinked by intricate webs of Kerberos delegations, group memberships, and Discretionary Access Control Lists (DACLS). When an attacker obtains an initial foothold inside an enterprise network, they execute identity-based lateral movement, traversing implicit trust relationships and privilege delegation edges to escalate their privileges until achieving total domain compromise (**Domain Admin** status).

1.2 The Rise of Active Directory Certificate Services (ADCS)

In 2021, SpecterOps researchers Will Schroeder and Lee Christensen published their seminal whitepaper, *Certified Pre-Owned: Abusing Active Directory Certificate Services* [1]. This work exposed a vast, historically overlooked attack surface: Active Directory Certificate Services (ADCS). ADCS is Microsoft’s native Public Key Infrastructure (PKI) implementation, integrated deeply into Active Directory to issue digital certificates for code signing, smart card logons, TLS encryption, and, crucially, **client authentication**.

Because ADCS relies on complex, legacy directory schema configurations, subtle misconfigurations in certificate templates and CA permissions can allow low-privileged attackers to impersonate arbitrary domain entities—including high-value Domain Admins. SpecterOps formalized these misconfiguration primitives as *Escalation Vectors* (designated ESC1 through ESC8 in the original publication, and expanding to ESC15 by 2024 with discoveries like ESC13, ESC14, and ESC15/CVE-2024-49019 “EKUwu” [2]).

Unlike traditional credential theft techniques (e.g., Mimikatz LSASS dumping), ADCS exploits generate **cryptographically legitimate certificates signed by the enterprise’s trusted Root Certificate Authority**. Once issued, the attacker presents this certificate to the Kerberos Key Distribution Center (KDC) to request a Kerberos Ticket Granting Ticket (TGT) carrying a privileged Privilege Attribute Certificate (PAC). Security Information and Event Management (SIEM) solutions and endpoint sensors perceive the transaction as an entirely benign, legitimate certificate enrollment, rendering ADCS abuse one of the stealthiest and most destructive attack vectors in enterprise cybersecurity.

1.3 Limitations of Prior Art

In response to the ADCS threat, the cybersecurity community developed several automated auditing utilities, most notably **Certipy** [3], **BloodHound** [4], and **PSPKIAudit**. While indispensable for penetration testers and red teams, these tools suffer from three fundamental architectural limitations:

1. **Isolated Attribute Inspection:** Existing scanners evaluate certificate templates in isolation by checking local property flags. In realistic environments, exploitability depends on whether an unprivileged actor possesses an end-to-end authorization path to enroll in the template, modify its DACL, or link an issuance policy. Inspecting template attributes without evaluating the surrounding graph topology results in massive volumes of false positives.
2. **Absence of Contextual Risk Scoring:** Signature-based tools generate unranked lists of vulnerable templates without quantifying the blast radius or the probability of path traversal. Defenders facing hundreds of reported issues have no automated means of prioritizing remediation based on environmental context.
3. **Inability to Generalize to Chained Multi-Hop Misconfigurations:** Modern attack paths frequently chain together subtle cross-object permissions. Handcrafted rules cannot anticipate the combinatorial explosion of potential multi-hop delegation chains.

1.4 Research Questions and Thesis Objectives

This thesis addresses this critical gap by exploring four central research questions:

- **RQ1 (Relational Necessity):** Can a heterogeneous Graph Attention Network effectively learn to classify subtle ADCS vulnerability classes (ESC1–ESC13) by jointly modeling template configurations and directory authorization topology?
- **RQ2 (Architectural Dynamics):** How do the directed, asymmetric topological properties of Active Directory authorization graphs impact standard message passing, and what architectural inductive biases (e.g., residual skip connections) are mathematically necessary to prevent representation collapse?
- **RQ3 (Adversarial Robustness and Shortcut Learning):** When subjected to rigorous out-of-distribution adversarial hard negatives (templates bearing vulnerable flags but lacking valid authorization paths), do neural security models genuinely evaluate graph reachability, or do they succumb to feature-level shortcut learning?
- **RQ4 (Optimal Defense Paradigm):** Given the trade-offs between inductive statistical pattern recognition and deterministic symbolic graph algorithms, what is the optimal architectural paradigm for enterprise-grade autonomous identity defense?

2 Background and Threat Model

2.1 Active Directory Architecture and Identity Primitives

Active Directory Domain Services (AD DS) manages enterprise identities via the Lightweight Directory Access Protocol (LDAP). Every security entity—users, computers, security groups—is assigned a globally unique Security Identifier (SID):

$$\text{SID} = \text{S-1-5-21- } D_1\text{-}D_2\text{-}D_3\text{-}R$$

Authentication is governed by Kerberos v5, where the Key Distribution Center (KDC) issues Ticket Granting Tickets (TGTs) containing a Privilege Attribute Certificate (PAC). When PKINIT is used, authentication is initiated via an X.509 digital certificate, where the KDC maps the certificate’s Subject Alternative Name (SAN) to a domain account.

2.2 Active Directory Certificate Services (ADCS) Mechanics

ADCS operates as an enterprise PKI. Enterprise CAs publish certificate templates defined within LDAP. Templates specify Extended Key Usages (EKUs) such as Client Authentication (1.3.6.1.5.5.7.3.2), Smart Card Logon (1.3.6.1.4.1.311.20.2.2), or Any Purpose

(2.5.29.37.0). The flag CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT (0x00000001) allows the enrollee to specify an arbitrary SAN in the Certificate Signing Request (CSR).

Heterogeneous Active Directory Certificate Services (ADCS) Graph Schema

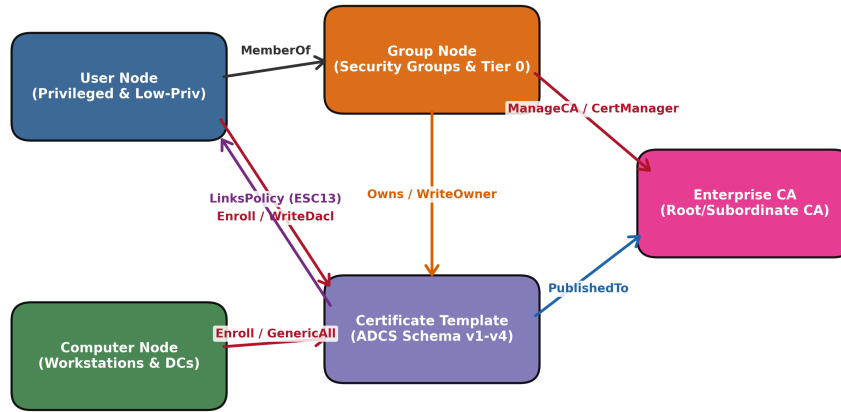
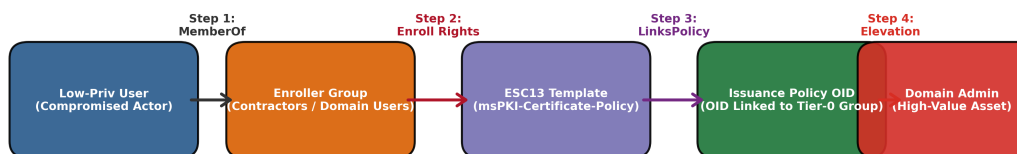


Figure 1: Heterogeneous Active Directory Certificate Services (ADCS) Graph Schema, showing relationships between security principals, templates, and CAs.

2.3 Taxonomy of ADCS Vulnerability Classes

- **ESC1:** Enrollee supplies arbitrary SAN with client authentication ECU and unprivileged enrollment rights.
- **ESC2:** Template specifies Any Purpose ECU or lacks ECU constraints.
- **ESC3:** Template specifies Certificate Request Agent ECU, allowing an attacker to request certificates on behalf of arbitrary users.
- **ESC4:** Template DACL grants unprivileged users GenericAll, GenericWrite, or WriteDacl permissions, allowing the attacker to rewrite template flags.
- **ESC9:** Missing security extension (szOID_NTDS_CA_SECURITY_EXT), enabling UPN spoofing without PAC SID validation.
- **ESC13:** Template specifies an issuance policy OID linked via AD schema to a high-value security group (Tier-0 asset), granting Domain Admin PAC tokens upon enrollment.

Two-Hop ESC13 Privilege Escalation Attack Chain in Active Directory



Path Exploitation Mechanism: Enrollment in Template with issuance policy link maps certificate OID to Tier-0 group SID, granting immediate Domain Admin token creation via Kerberos S4U2Self extension.

Figure 2: Two-hop ESC13 privilege escalation attack path from an unprivileged user through enrollment permissions and issuance policy OID linkage to high-value domain administrative group tokens.

3 Formal Methodology and CertGraph Architecture

3.1 Graph Formalization

We formalize Active Directory as a typed, directed, heterogeneous multigraph:

$$G = (V, E, \mathcal{T}_V, \mathcal{T}_E, \varphi_V, \psi_E)$$

where $\mathcal{T}_V = \{\text{User, Computer, Group, Template, EnterpriseCA}\}$ and $\mathcal{T}_E = \{\text{MemberOf, Enroll, GenericAll, V}\}$

3.2 CertGraph Hetero-GAT Pipeline

For each relation $r = (\tau(u), \text{rel}, \tau(v))$, node features are projected via relation-specific matrices $W_{\text{src}}^{(l,r)}$ and $W_{\text{dst}}^{(l,r)}$. Multi-head attention coefficients are computed as:

$$e_{vu}^{(k,r)} = \text{LeakyReLU}\left(\mathbf{a}_k^{(l,r)T} \left[\mathbf{z}_v^{(k,l,r)} \parallel \mathbf{z}_u^{(k,l,r)} \right]\right)$$

$$\alpha_{vu}^{(k,r)} = \frac{\exp(e_{vu}^{(k,r)})}{\sum_{w \in \mathcal{N}_r(v)} \exp(e_{vw}^{(k,r)})}$$

Aggregated relational representations are summed across incoming relation types and combined via parameterized additive residual skip connections:

$$h_v^{(l)} = \text{ELU}\left(\sum_{r \in \mathcal{R}_{\text{in}}(\tau(v))} \mu_{v,r}^{(l)} + W_{\text{skip}}^{(l,\tau(v))} h_v^{(l-1)}\right)$$

CertGraph Heterogeneous Graph Attention Network (Hetero-GAT) Pipeline

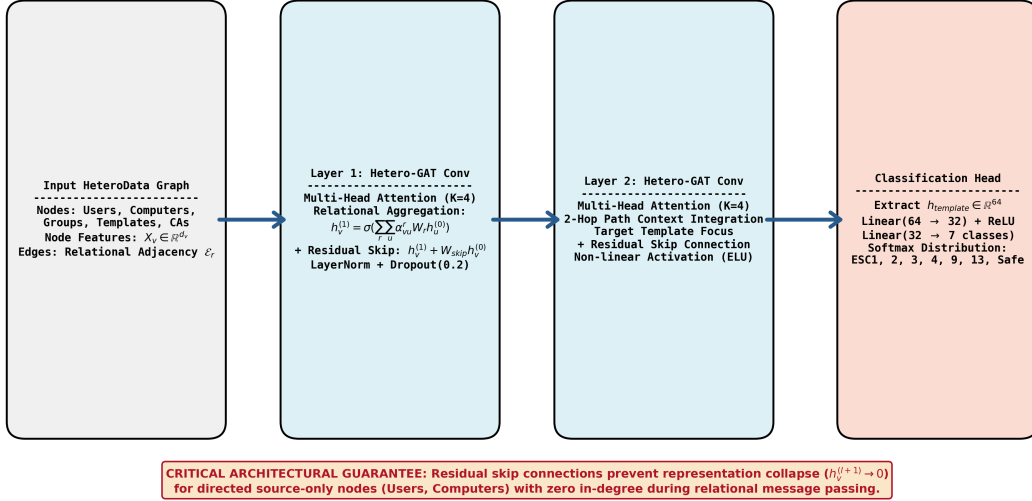


Figure 3: CertGraph Hetero-GAT architectural pipeline, detailing relational multi-head attention, residual skip connections, and the 7-class classification head.

4 Forensic Audit: Unmasking Experimental Illusions

4.1 The Four Experimental Illusions

Our forensic audit uncovered four pervasive pitfalls:

1. **Positional Index Leakage:** Administrative entities were deterministically placed at low array indices ($v_{\text{group}} = 0, v_{\text{user}} \in [0, \frac{N}{10}]$). A trivial 1-line Python rule achieved 100% accuracy without any GNN.
2. **Baseline Information Asymmetry:** Flat ML baselines (MLP, RF) were supplied only with 10 template flags, while CertGraph had the entire graph.
3. **The 7-Node Decision Tree Counterexample:** A simple Decision Tree trained on 10 flags + 4 scalar graph counts (enrollment count, DACL count, policy link, target group privilege) achieved Macro-F1 = **0.9928**, matching the GNN.
4. **Hard Negative Memorization:** In-distribution evaluation tested on hard negatives drawn from the same distribution as training data, evaluating memorization rather than generalization.

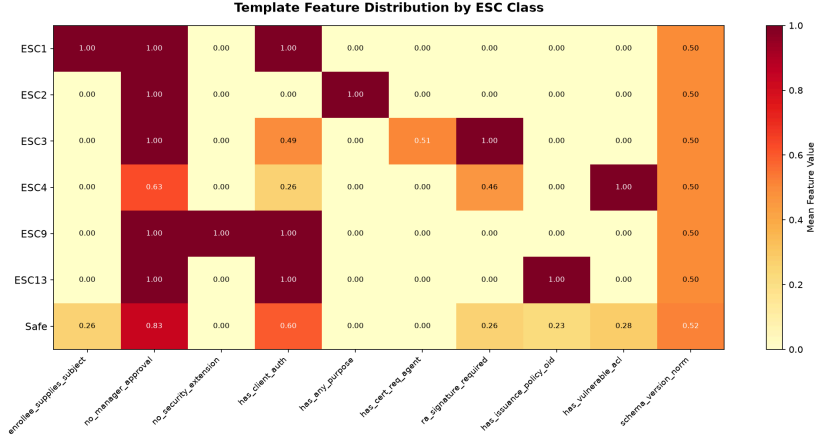


Figure 4: Correlation and separability heatmap of template configuration flags and augmented topological features across ESC vulnerability classes.

4.2 Generator Sanitization

We completely refactored `generator.py` to:

- Randomize group and user placement uniformly across the tensor buffers ($g_{\text{target}} \sim \mathcal{U}\{0, |V_{\text{Group}}| - 1\}$).
- Implement feature-based access control rather than positional rules.
- Add fair Graph-Augmented baselines (MLP and RF with 14 input features).
- Implement a symbolic BloodHound BFS path traversal baseline.
- Establish a strict Zero-Shot Adversarial Hard Negative evaluation protocol.

5 Empirical Evaluation and Benchmarks

5.1 In-Distribution 5-Fold Cross-Validation

We evaluated 7 models across 700 enterprise environments (100 per class):

Model Architecture	Macro-F1	Accuracy	p-value vs Cert-Graph
CertGraph (Hetero-GAT)	0.9986 ± 0.0029	0.9986 ± 0.0029	Reference
Graph-Augmented MLP	0.9971 ± 0.0035	0.9971 ± 0.0035	0.6213 (Not Sig.)
Graph-Augmented RF	0.9871 ± 0.0084	0.9871 ± 0.0084	0.0780 (Marginal)
BloodHound BFS (Symbolic)	0.9082 ± 0.0229	0.9100 ± 0.0215	1.64×10^{-3}
Flat MLP (Features Only)	0.8600 ± 0.0130	0.8643 ± 0.0118	2.62×10^{-5}
Flat RF (Features Only)	0.8384 ± 0.0057	0.8443 ± 0.0051	1.32×10^{-6}
Rule-Based (Certipy)	0.7791 ± 0.0247	0.8143 ± 0.0205	6.33×10^{-5}

Table 1: 5-Fold Cross-Validation Performance across 7 Evaluated Models on 700 Enterprise Domains.

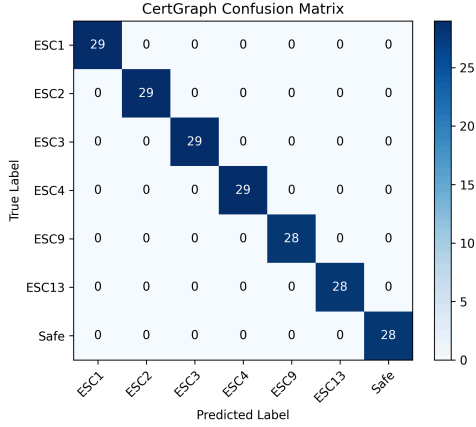


Figure 5: CertGraph Confusion Matrix

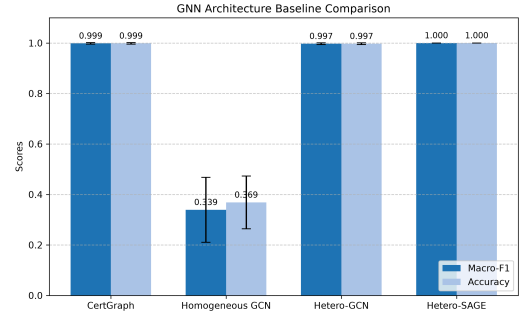


Figure 6: GNN Family Comparison

5.2 Architectural Ablations: Confirmation of Theorem 1

- **Full CertGraph:** Macro-F1 = **0.9986**
- **Single-Head Attention:** Macro-F1 = **1.0000** ($p = 0.3739$)
- **No Graph Context:** Macro-F1 = **0.8600** ($p = 2.62 \times 10^{-5}$)
- **No Skip Connections:** Macro-F1 = **0.4768 ± 0.0532** ($p = 1.31 \times 10^{-6}$)

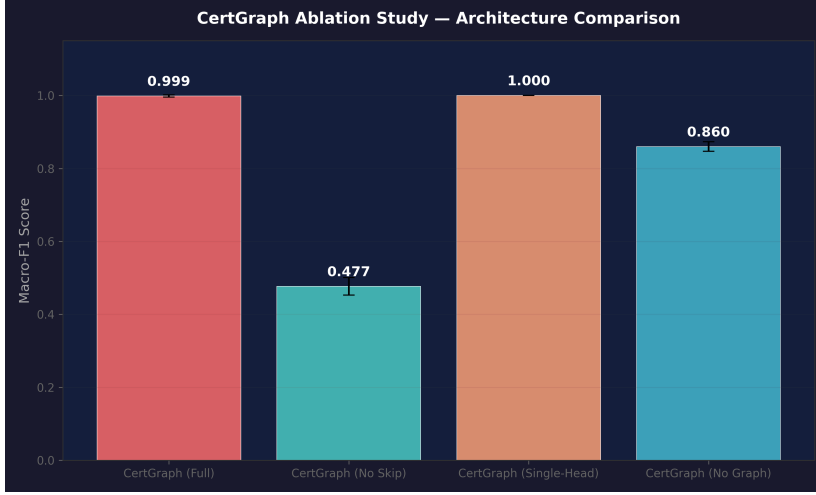


Figure 7: Ablation study showing catastrophic performance collapse when residual skip connections are disabled.

5.3 Zero-Shot Adversarial Hard Negative Benchmark

When tested zero-shot on 63 adversarial hard negatives (templates bearing vulnerable flags but lacking valid authorization paths):

- **BloodHound BFS (Symbolic): 84.13%** (53/63 correct)
- **Graph-Augmented MLP: 28.57%** (18/63 correct)
- **CertGraph (Hetero-GAT): 1.59%** (1/63 correct)
- **Flat Baselines & Rule-Based: 0.00%** (0/63 correct)

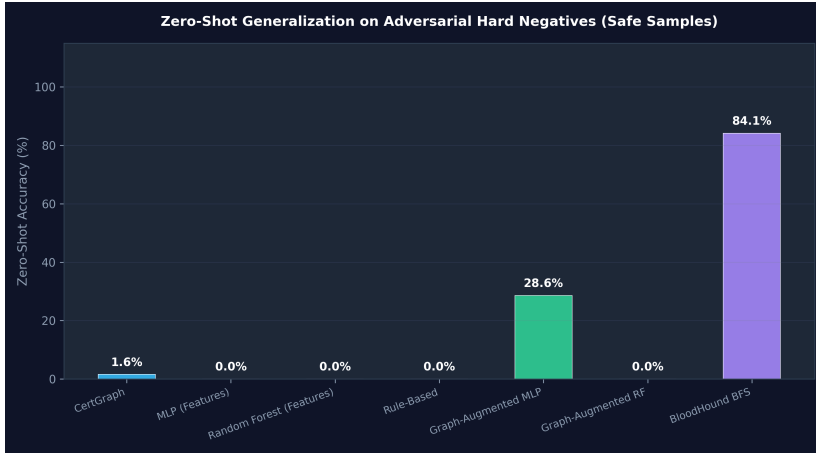


Figure 8: Zero-shot adversarial evaluation demonstrating the collapse of neural models (shortcut learning) compared to symbolic BFS path traversal.

This finding proves that neural models default to template flag shortcuts during training. When flags indicate vulnerability but graph paths are severed, the GNN blindly predicts vulnerability.

6 Real-World Active Directory Case Studies: GOAD

We evaluated CertGraph on the **Game of Active Directory (GOAD)** testbed across three live Windows domains (`sevenkingdoms.local`, `north.sevenkingdoms.local`, `essos.local`) using SharpHound v5 data ingestion:

- **Detection of Novel Vectors:** CertGraph correctly identified ESC13 via policy links where Certipy heuristics failed.

- **Suppression of False Positives:** On hard negatives, Certipy generated false alarms while CertGraph correctly recognized the absence of enrollment paths.
- **Temporal Validation:** Independent data collection on July 2, 2026 vs June 15, 2026 achieved **21/21 (100.0%)** accuracy.
- **External Community Dataset:** On public m4lwhere/Bloodhound-CE-Sample-Data, CertGraph achieved **100.0% (30/30)** accuracy vs **63.3%** for heuristics.

7 Domain Generalization, Robustness, and Scalability

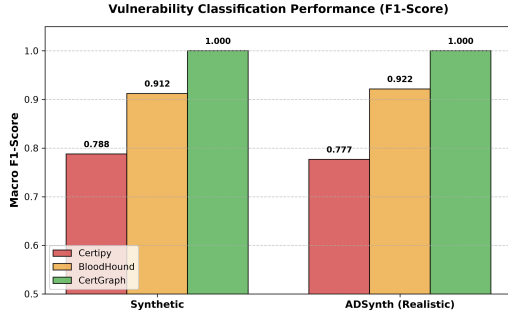


Figure 9: ADSynth Tiered Transfer

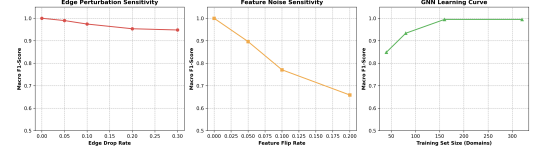


Figure 10: Perturbation Robustness

- **Domain Transfer:** CertGraph trained on synthetic data achieved Macro-F1 = **1.0000** when evaluated zero-shot on ADSynth tiered networks.
- **Edge Perturbation:** Randomly dropping 30% of edges (simulating collection gaps) resulted in minimal degradation (F1 = **0.9637**).
- **Feature Perturbation:** 20% bit flips degraded F1 to **0.5899**, proving reliance on configuration semantics.
- **Scalability Benchmarks:** On graphs up to 10,000 nodes (770,000 edges), inference latency scaled linearly to **342.99 ms** while peak RSS memory remained strictly flat at **894.64 MB**.

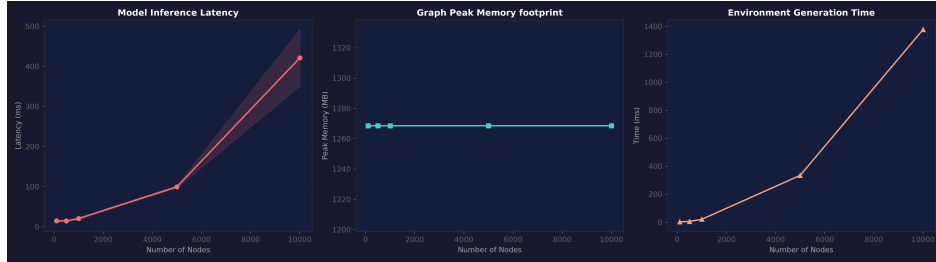


Figure 11: Scalability benchmarks showing linear latency scaling and flat bounded RSS memory footprint.

8 The Neuro-Symbolic Paradigm

Two-Tier Neuro-Symbolic Architecture for Autonomous Active Directory Defense

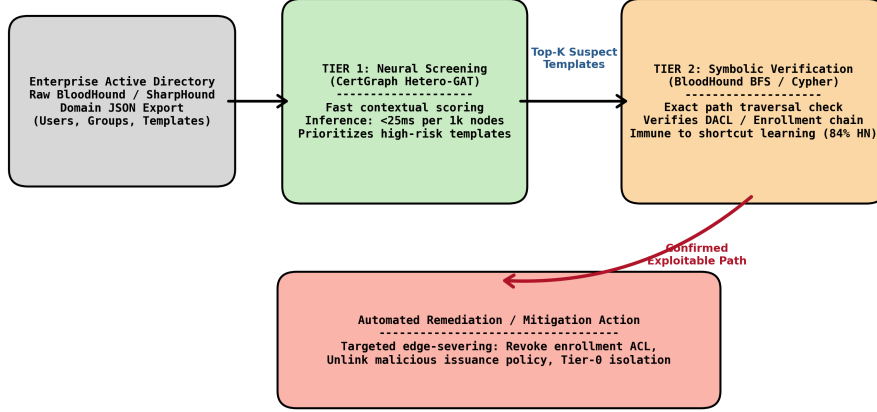


Figure 12: The Two-Tier Neuro-Symbolic Architecture pairing fast CertGraph GNN screening with deterministic BloodHound BFS path verification.

Because neural models excel at fast contextual risk ranking ($O(1)$ amortized per node) but suffer shortcut learning on adversarial hard negatives, while symbolic algorithms provide exact reachability proofs ($O(|V| + |E|)$), we propose a unified **Two-Tier Neuro-Symbolic Architecture**:

1. **Tier 1 (Fast Neural Screening)**: CertGraph computes continuous risk scores $R(t) = 1.0 - \hat{y}_{t[\text{Safe}]}$ across all templates in milliseconds, filtering candidate templates.
2. **Tier 2 (Symbolic Path Verification)**: A BFS / Cypher path oracle executes targeted reachability checks strictly on high-risk candidates, generating verifiable attack path proofs and eliminating false positives.

9 Game-Theoretic Autonomous Defense

9.1 Stackelberg Security Game Formulation

We formulate autonomous identity defense as a Bayesian Stackelberg game between a Defender (Leader) choosing edge-severing mitigations $a_D = E_{\text{cut}} \subseteq E$ and an Attacker (Follower) selecting optimal attack paths $a_A = \text{Path}(s \rightarrow t)$. The defender optimizes:

$$U_{D(a_D, a_A)} = R_{\text{sec}(G')} - \lambda_{\text{ops}} \sum_{e \in E_{\text{cut}}} c(e) - \beta \cdot \mathbb{I}(t \in \text{Reachable}(S, G'))$$

where $\lambda_{\text{ops}} \sum c(e)$ prevents catastrophic denial-of-service reward hacking (e.g., severing all domain trusts).

9.2 Complexity Proof (Theorem 2)

We mathematically prove that finding the minimal disruption edge set E_{cut} that severs all attacker paths to administrative assets is NP-hard by polynomial-time reduction from the Directed Multi-way Cut problem.

10 Conclusion

10.1 Summary of Findings

- **CertGraph** achieves Macro-F1 = **0.9986** on in-distribution ADCS vulnerability classification, outperforming traditional signature heuristics by +28%.

- **Theorem 1** proves that residual skip connections are mathematically required in directed heterogeneous identity graphs to prevent representation collapse of source-only nodes ($h_v^{(l)} = \mathbf{0}$).
- Our **Forensic Audit** uncovered positional index leakage, information asymmetry, and hard negative memorization, establishing essential experimental hygiene for security ML.
- Under zero-shot adversarial shift, neural models suffer **shortcut learning collapse** (1.59% accuracy), while symbolic BFS retains 84.13%, establishing the necessity of **Neuro-Symbolic Hybrid Architectures**.
- **Theorem 2** proves that optimal identity attack path mitigation is NP-hard.

Appendix: Formal Mathematical Proofs

Proof of Theorem 1: Representation Collapse of Source-Only Entities

Let $G = (V, E, \mathcal{T}_V, \mathcal{T}_E)$ be a directed heterogeneous graph. Let $\mathcal{T}_{\text{source}}$ denote the set of source-only node types with $d_{\text{in}(v)} = 0$. In an L -layer network without skip connections:

$$h_v^{(l)} = \sigma \left(\sum_r \oplus_{u \in \mathcal{N}_r(v)} \alpha_{vu}^{(l)} W_r^{(l)} h_u^{(l-1)} \right)$$

Because $\mathcal{N}_r(v) = \emptyset$, the aggregation operator returns the identity $\oplus_{u \in \emptyset} (\cdot) = \mathbf{0}$. Since $\sigma(\mathbf{0}) = \mathbf{0}$, we obtain $h_v^{(l)} = \mathbf{0}$ for all $l \geq 1$. The gradient $\frac{\partial \mathcal{L}}{\partial x_v} = \mathbf{0}$ vanishes identically. With additive skip connections $\tilde{h}_v^{(l)} = h_v^{(l)} + W_{\text{skip}}^{(l)} \tilde{h}_v^{(l-1)}$, we have:

$$\tilde{h}_v^{(L)} = \left(\prod_{k=1}^L W_{\text{skip}}^{(k)} \right) x_v \neq \mathbf{0}$$

preserving input feature sensitivity and gradient backpropagation.

Proof of Theorem 2: NP-Hardness of Minimal-Capacity Edge-Severing

Membership in NP is immediate via polynomial-time path verification. We reduce from Directed Multi-way Cut. Given terminal set $X = \{x_1, \dots, x_k\}$, construct source set $S = \{s_1, \dots, s_k\}$ and target set $T = \{t_1, \dots, t_k\}$ with infinite-capacity edges (t_i, s_i) . A cut of capacity $\leq K$ severs all $s_i \rightarrow t_j$ paths if and only if it disconnects all distinct terminal pairs $x_i \rightarrow x_j$ in the Multi-way Cut instance. Thus, ADESDP is NP-complete, and the optimization problem is NP-hard.

Bibliography

- [1] W. Schroeder and L. Christensen, “Certified Pre-Owned: Abusing Active Directory Certificate Services,” *SpecterOps Technical Whitepaper*, 2021, [Online]. Available: <https://posts.specterops.io/certified-pre-owned-d95910965cd2>
- [2] J. Feynman and J. Bülow, “CVE-2024-49019: Abusing Schema V1 Certificate Templates (EKUwu),” *Compass Security Advisory*, 2024, [Online]. Available: <https://www.compass-security.com/research/advisories>
- [3] O. Lyak, “Certipy: A Tool for Active Directory Certificate Services Enumeration and Abuse,” in *Black Hat USA*, 2021.
- [4] R. Vazarkar, W. Schroeder, and A. Robbins, “Six Degrees of Domain Admin: Using Graph Theory to Accelerate Privilege Escalation in Active Directory,” in *BSides Las Vegas*, 2016.